PCAO-F · FOUNDATIONS

Governance, Risk & Responsible Use

4 questions. 3 answers. 1 hard scenario, solved step by step.

Fully appropriate

Low risk, reversible. No special gate.

Appropriate with review

A named human check runs BEFORE use.

Inappropriate

Review cannot repair it. Stays human-owned.

“Classify before you act. If the answer is in the middle, name the commitment. Then write down why.”

The 4 Questions + the Record

Question	Quick check	Tool to use	Middle answer needs
1 · Case	Can AI do this work responsibly?	4 screens, reversibility first	A gate: Who · What · When
2 · Data	Can this info go in by this route?	Green / Yellow / Red tiers	Minimise, add a control, or confirm the route
3 · Capability	Should this tool be switched on?	5 checks: Source, Reach, Fit, Outside content, Actions	A specific security / admin question
4 · People	Unfair to someone? Disclosure needed?	Sample the exclusions	Fairness check, disclosure or escalation
+ Record	Can someone see why we decided?	One page of decisions	Blank field = OPEN QUESTION, routed

8 Rules the Exam Loves

1 · A gate has 3 parts

Who (a role) · What (the risk) · When (before use). “Someone will check” is only an intention.

2 · Unsure? Go higher

Between two data tiers, pick the higher. A key kept = pseudonymised, not anonymous.

3 · Privacy feature ≠ permission

Incognito, sandbox, project: none means the route is approved.

4 · Skills inherit reach

A Skill has no permission dial. It reaches all your session can.

5 · Outside content = injection

Web, incoming email, customer text can steer a trusted tool. Send / pay / delete stay with a human.

6 · Sample the exclusions

AI narrows, humans see survivors. Review a sample of what was removed.

7 · Disclosure: 2 questions

Does law, policy, contract or client require it? Would AI use change their understanding?

8 · Mistake? First hour

Stop the spread, record facts, report, follow the owner. Never delete quietly.

The ROW Method: 3 passes, about 60 seconds

R

Read the ask

What are you hunting? Underline the word FIRST. Scan top to bottom and stop at the first wrong row.

O

Open each row against its rule

The Question column tells you the rule. Ask “does it match the rule exactly?”, not “does it sound professional?”

W

Whittle the options

Kill extremes, do-nothing answers and options that fix a later row. Keep the one naming the exact rule.

Trap words: always · never · cannot · whatever · someone will check · a colleague confirmed · our own

4 wrong options: too loose · too strict · right rule, wrong row · false comfort

Scenario: Indus Telecom, “Complaint Desk”

An AI Skill reads ~4,000 weekly complaints, tags high or low priority, drafts replies and creates refund requests (up to Rs 5,000). Low priority gets a fixed message and no human reads it. Zara's session can read/write the drive and create/release payments.

#	Question	What Zara recorded
1	Case	Review needed; gate before reply is sent and before refund release
2	Data	Masked IDs and cards, no key kept, now Yellow, approved workspace
3	Source	Built by Billing Systems; their lead confirmed it by phone
4	Reach · Fit · Actions	Drive read-only, payments create-only, release stays with Team Lead
5	Outside content	“Our own verified customers, so our own material.” Enable
6	Fairness	Checked 50 high-priority tags and every refund: all accurate
7	Record	One page; unknown fields written as OPEN QUESTION and routed
8	Incident (week 2)	Hidden white-text refund order in a complaint; deleted it, told no one

Which is the first step at which Zara's work departs from the method?

A **Step 6.** Low-priority complaints are never read by a person, so whoever is removed is never seen.

B **Step 1.** A refund that cannot be recalled makes the use case inappropriate, so no gate should exist.

C **Step 5.** Complaint text is written by people outside the company, so even a trusted Skill is exposed to hidden instructions.

D **Step 2.** The emails began as Red data, so the masked copy stays Red and cannot enter the approved workspace.

Pause here and try it yourself with R · O · W.

Solving it: open each row against its rule

#	Rule held up	Verdict
1	Gate = who / what / when	OK. Role, risk and timing named
2	Data tier, identifiers, route	OK. Masked, no key, Yellow, approved route
3	Source check	OK. Publisher confirmed directly
4	Reach · Fit · Actions	OK. Narrowed; release stays human
5	Outside content	FIRST WRONG STEP. Customer text is written outside the company
6	Sample the exclusions	Real flaw, but later (bait)
7	Blank = OPEN QUESTION	OK. Unknowns routed
8	Incident: first hour	Real flaw, but later (bait)

FIRST means: walk down from Step 1 and stop at the first cross. Louder mistakes further down are bait.

Answer: C (Step 5, Outside content)

Why C

Complaint text is written by people outside the company, so it is outside content even though the customers are “ours”.

The source check passed, so the risk sits in what the Skill reads. Week 2's white-text email proves it.

Why not the others

A: real flaw, wrong moment. Step 6 comes after Step 5.

B: right rule, wrong row. Irreversible means a stronger gate, not a ban.

D: too strict. Masking + no key + approved route is a valid path.

What Zara should have done at Step 5

Treat complaint text as outside content, keep every action (refund, send) behind a human, and ask: “Can Complaint Desk read and tag only?”

R · Read the ask O · Open each row W · Whittle the options